



UNIVERSIDAD SANTO TOMAS SECCIONAL TUNJA

Facultad de ingeniería de sistemas

**INFORME DE LABORATORIO – INTERCEPTACIÓN Y MANIPULACIÓN DE
FORMULARIOS WEB CON BURP SUITE**

ESPACIO ACADEMICO:

Ciberseguridad Blue Team y White hat

PRESENTADO A:

Sergio Arley Puerto Moreno

AUTORES:

Karol Mariana Acuña Barrera

Diana Marcela Ayala

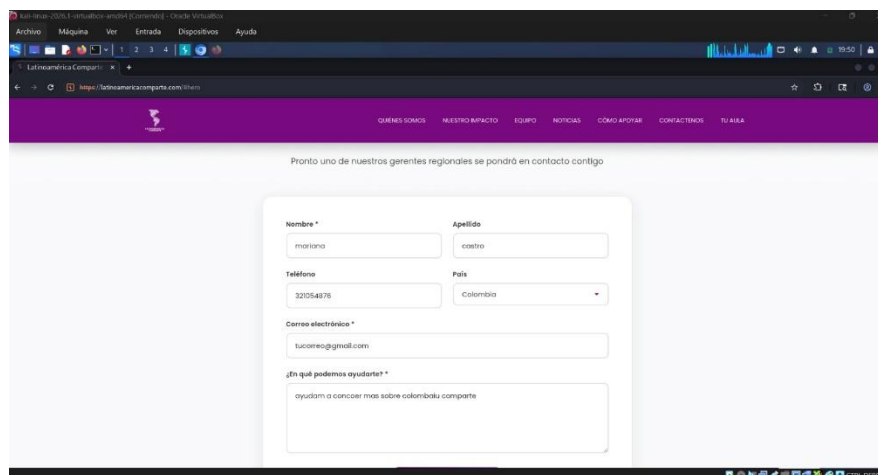
Juan Camilo Calderon

Juan David Jojoa

2026

El objetivo de este laboratorio fue demostrar cómo un formulario web puede ser interceptado, analizado y manipulado desde un entorno externo al sitio original, utilizando herramientas de análisis de tráfico como Burp Suite. A partir de las evidencias capturadas, se buscó comprobar si existían validaciones del lado del servidor y qué tan efectivas eran las medidas de seguridad implementadas para evitar envíos no autorizados del formulario.

Para el desarrollo de la práctica se utilizaron herramientas como Kali Linux, Burp Suite Community y el navegador Firefox configurado con proxy. El análisis se realizó sobre el formulario de contacto del sitio **Latinoamérica Comparte**, el cual envía la información a través del servicio externo **Web3Forms** en lugar de procesarla directamente en el servidor del sitio.

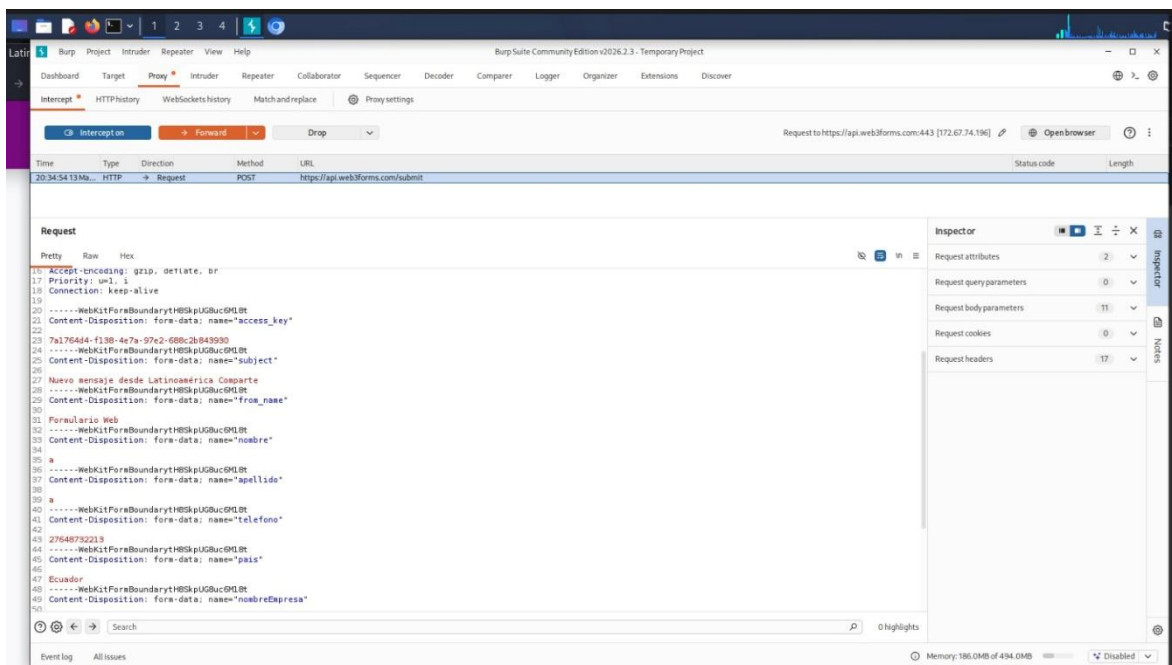


```
5 Accept-Language: en-US,en;q=0.9
6 Accept: application/json
7 Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
8 Content-Type: multipart/form-data; boundary=---WebKitFormBoundarytH8SkpUG8uc6M18t
9 Sec-Ch-Ua-Mobile: 70
10 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
11 Origin: https://google.com
12 Sec-Fetch-Site: cross-site
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: https://latinoamericacomparte.com/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=1, i
18 Connection: keep-alive
19
20 -----WebKitFormBoundarytH8SkpUG8uc6M18t
21 Content-Disposition: form-data; name="access key"
```

time	type	direction	method	url
20:34:54.134	HTTP	→ Request	POST	https://api.web3forms.com/submit
20:38:08.134	HTTP	→ Request	GET	https://www.google.com/warmup.html

```
Request
Pretty Raw Hex
1 GET /warmup.html HTTP/2
2 Host: www.google.com
3 Cookie: AEC=AAJas5v5v00Hd5N0smaR6y0kP1smr3EL6eYBgluJeeZjXSHZT4vuzJaw; __Secure-BUCKET=CH8H; __Secure-STRT=
AEEPTu167Tg59qetA0d24U1AF3NAK0apzA3akayCe1_HuRAzPhZuJDeMD01N0NN0u0Y2C3B40QntETH0yWffHdz0SCEDGxyv; NID=
533=JERTES19p9P7te_130K7N0Gm...yH0duVp0u0gSV...vH0MfH0uH0B0gUd0J0J2U0uH0G0Q2tBr0B0gH7YcUzBRK029wH0N0V1H8k13Q1E1B0C-
AHT0a1Fh2Lk1gF_cogEtF3yHw0L9F5PC0Kawp0YEGFQZ7BDF9-CB00VbLv0kVkyT_E9HcEn2W0888w
4 Rtt: 200
5 DnsLink: 5.35
6 Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
7 Sec-Ch-Ua-Mobile: 70
8 Sec-Ch-Ua-Full-Version: **
9 Sec-Ch-Ua-Arch: **
10 Sec-Ch-Ua-Platform: "Linux"
11 Sec-Ch-Ua-Platform-Version: **
12 Sec-Ch-Ua-Model: **
13 Sec-Ch-Ua-Bitness: **
14 Sec-Ch-Ua-Wow64: 70
15 Sec-Ch-Ua-Full-Version-List:
16 Sec-Ch-Ua-Form-Factors:
17 Sec-Ch-Prefers-Color-Scheme: dark
18 Accept-Language: en-US,en;q=0.9
19 Upgrade-Insecure-Requests: 1
20 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
21 Sec-Purpose: prefetch:render
22 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
23 X-Client-Data: Chellyv6
24 Sec-Fetch-Site: none
25 Sec-Fetch-Mode: navigate
26 Sec-Fetch-User: ?1
27 Sec-Fetch-Dest: document
28 Accept-Encoding: gzip, deflate, br
29 Priority: u=0, i
30
```

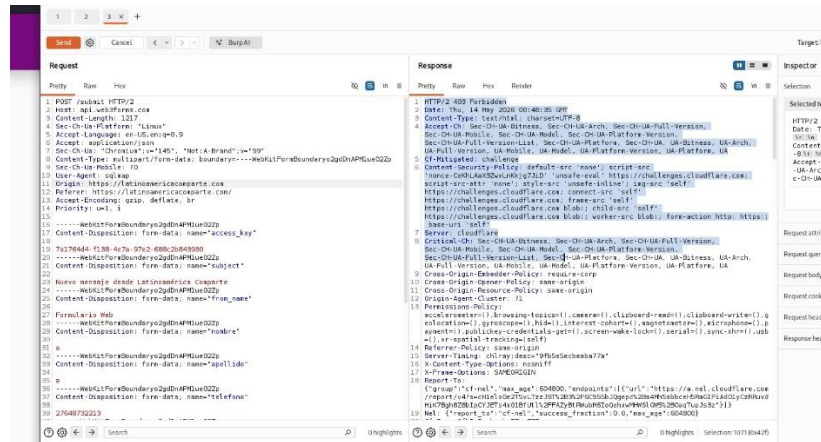
Durante la primera fase se identificó, desde el historial HTTP de Burp Suite, que al enviar el formulario se generaba una petición de tipo POST hacia la URL <https://api.web3forms.com/submit>. Este hallazgo permitió concluir que el formulario no depende del backend propio del sitio, sino que delega completamente el procesamiento de los datos a un servicio de terceros. Esta observación fue clave para entender el flujo real de la información.



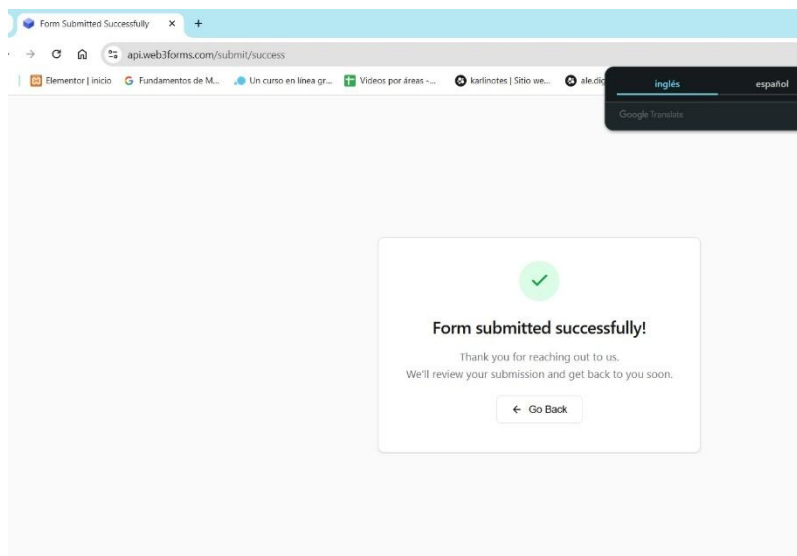
En la segunda fase, con la opción “Intercept ON”, se capturó la petición antes de que saliera del navegador. Allí fue posible visualizar todos los campos enviados en el cuerpo del mensaje bajo el formato multipart/form-data, incluyendo datos como nombre, apellido, teléfono, país y mensaje, además de un parámetro denominado access_key. Esto evidenció que los datos viajan en texto claro y que pueden ser fácilmente manipulados antes de llegar al servidor destino.

Posteriormente, la petición interceptada fue enviada a la herramienta Repeater de Burp Suite, donde se modificaron manualmente varios valores de los campos del formulario. A pesar de alterar completamente la información original, el servidor respondió aceptando la solicitud sin presentar errores ni rechazos. Esto permitió comprobar que no existen validaciones estrictas del lado del

servidor sobre la coherencia o legitimidad de los datos recibidos.



En la siguiente etapa del laboratorio se creó un archivo HTML local en el equipo, ejecutado desde la dirección 127.0.0.1, que contenía un formulario apuntando directamente a la misma URL de envío de Web3Forms. Al enviar este formulario externo, el sistema mostró el mensaje “Form submitted successfully”, demostrando que el servicio acepta solicitudes provenientes de cualquier origen, incluso cuando no provienen del dominio legítimo del sitio analizado.



El análisis de las cabeceras de respuesta del servidor mostró la presencia de mecanismos de seguridad como protección de Cloudflare, políticas CORS, X-Frame-Options y otras cabeceras orientadas a la seguridad. Sin embargo, estas medidas no impidieron que el formulario fuera enviado desde un origen no autorizado, lo que indica que la protección está aplicada a nivel perimetral, pero no en la validación específica del servicio que procesa el formulario.

A partir de todo lo observado, se concluye que el problema principal no reside directamente en el sitio de Latinoamérica Comparte, sino en la forma en que está implementado el formulario al confiar plenamente en un servicio externo que solo valida la presencia de una `access_key`. Cualquier persona que logre interceptar esta clave puede reutilizarla para enviar formularios falsos, suplantando el origen legítimo del mensaje.

En conclusión, el laboratorio demostró que es posible interceptar, modificar y reenviar peticiones del formulario desde un entorno completamente ajeno al sitio original. Aunque existen mecanismos de seguridad visibles, el servicio encargado de procesar los datos no valida adecuadamente el origen de las solicitudes, lo que permite la suplantación de formularios y representa una vulnerabilidad conocida como “Form Spoofing”.